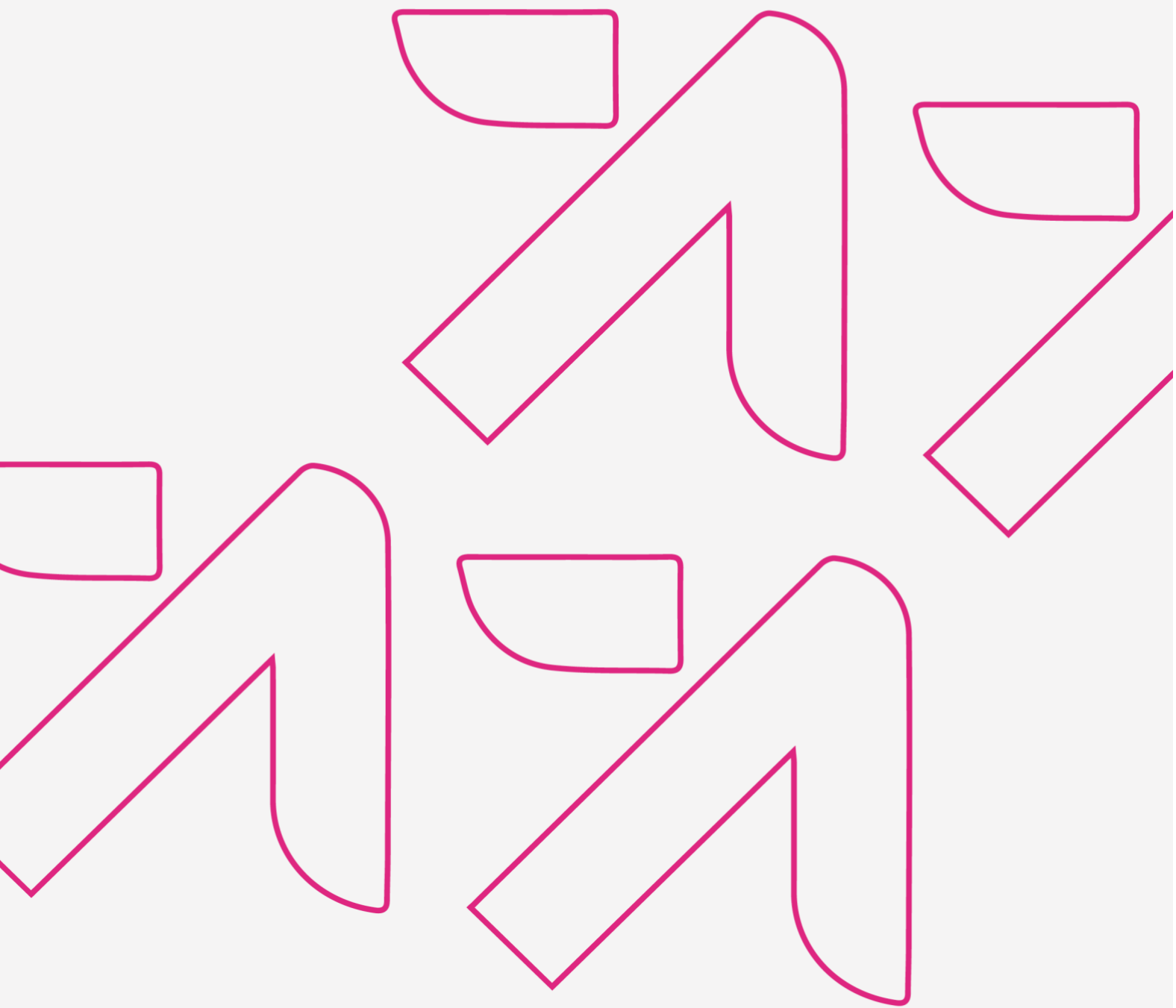




Máster de

# Ciberseguridad Hacking Ético

[Módulo Bastionado de Redes y Sistemas]

Curso académico 2026/2027 - Edición Presencial

## UT7. Seguridad en entornos cloud

**Encaje en el curso 2026/2027:** esta unidad amplía la parte de seguridad de la nube del RA5 (tema 9) y aplica en cloud lo visto en redes (RA4) e identidades (RA2 y RA3).

### 1. Objetivo

Bastionar un entorno cloud consiste en aplicar los mismos principios que en un centro de datos propio (mínima exposición, mínimo privilegio, cifrado, registro) a una infraestructura que se crea y se destruye con una llamada a una API.

La mayoría de incidentes en la nube no se deben a fallos del proveedor, sino a errores de configuración del cliente: un almacenamiento público, una clave filtrada o un puerto de administración abierto a todo Internet.

### 2. Responsabilidad compartida

El proveedor responde de la seguridad **de** la nube (centros de datos, hardware, hipervisor). El cliente responde de la seguridad **en** la nube (lo que despliega y cómo lo configura). El reparto cambia según el modelo de servicio:

| Capa                        | IaaS      | PaaS       | SaaS      |
|-----------------------------|-----------|------------|-----------|
| Datos e identidades         | Cliente   | Cliente    | Cliente   |
| Aplicación                  | Cliente   | Cliente    | Proveedor |
| Sistema operativo y parches | Cliente   | Proveedor  | Proveedor |
| Red virtual y firewall      | Cliente   | Compartido | Proveedor |
| Infraestructura física      | Proveedor | Proveedor  | Proveedor |

La idea clave: los datos, las identidades y la configuración son siempre responsabilidad del cliente, en cualquier modelo.

### 3. IAM cloud

- Cuenta raíz protegida con MFA fuerte y sin uso diario.
- Roles y credenciales temporales en lugar de claves permanentes.
- Mínimo privilegio en las políticas: sin comodines en acciones ni en recursos.
- Federación con el directorio corporativo e inicio de sesión único.
- Separación por cuentas, suscripciones o proyectos: producción, preproducción y pruebas no comparten entorno.
- Límites organizativos (políticas de organización, SCP) que nadie dentro de la cuenta puede saltarse.

## 4. Redes en cloud

### 4.1. Diseño de la red virtual

- Red virtual propia (VPC en AWS y Google Cloud, VNet en Azure) con subredes públicas y privadas.
- En la subred pública solo vive lo que debe recibir tráfico de Internet: balanceadores y proxies inversos.
- Servidores de aplicación y bases de datos en subredes privadas, sin IP pública.
- Salida a Internet de las subredes privadas a través de una pasarela NAT.

### 4.2. Filtrado

- Grupos de seguridad con denegación por defecto y reglas que referencian a otros grupos, no rangos amplios.
- Nunca 0.0.0.0/0 hacia SSH (22), RDP (3389) o puertos de bases de datos.

### 4.3. Administración

- Acceso de administración mediante bastión gestionado o gestor de sesiones (Session Manager, Azure Bastion), sin abrir puertos.
- Conexión privada con los servicios del proveedor (*private endpoints*) para que el tráfico no salga a Internet.
- WAF y protección DDoS delante de lo que se publica.

## 5. Almacenamiento seguro

El almacenamiento de objetos (buckets de S3, contenedores de Blob Storage) es el origen clásico de las fugas de datos en la nube.

- Bloqueo de acceso público activado a nivel de cuenta.
- Políticas de acceso explícitas y revisadas; nada de «cualquier usuario autenticado».
- Cifrado en reposo activado y obligación de usar TLS.
- Versionado y bloqueo de objetos (inmutabilidad) frente a borrados y ransomware.
- Registro de accesos activado.
- Enlaces temporales (URL prefirmadas, SAS) con caducidad corta en lugar de hacer público el recurso.

## 6. Cifrado

### 6.1. En reposo

Discos, bases de datos, almacenamiento y copias de seguridad cifrados. La mayoría de servicios lo ofrecen con solo activarlo.

## 6.2. En tránsito

TLS 1.2 o superior en todas las conexiones, también en las internas entre servicios.

## 6.3. Gestión de claves

- Servicio de gestión de claves (KMS, Key Vault) con claves gestionadas por el cliente cuando los datos lo justifiquen.
- Rotación automática de claves.
- Separación de funciones: quien administra las claves no es quien accede a los datos.
- Contraseñas, tokens y certificados en un gestor de secretos, nunca en variables en claro ni en el código.

## 7. Bases de datos cloud

- Sin acceso público: solo desde las subredes o grupos de seguridad de la aplicación.
- Autenticación mediante IAM o el directorio corporativo cuando el servicio lo permita.
- Cifrado en reposo y TLS obligatorio.
- Copias automáticas con recuperación a un punto en el tiempo, y pruebas reales de restauración.
- Auditoría de consultas y de inicios de sesión activada.
- El parcheo del motor lo hace el proveedor, pero la ventana de mantenimiento y las versiones mayores las decide el cliente.

## 8. Monitorización y auditoría

- Registro de todas las llamadas a la API de gestión (CloudTrail, Azure Activity Log, Cloud Audit Logs), en todas las regiones y guardado en una cuenta separada.
- Registros de flujo de red (*flow logs*) para saber quién habla con quién.
- Detección de amenazas nativa (GuardDuty, Defender for Cloud, Security Command Center).
- Gestión de la postura de seguridad (**CSPM**): revisa de forma continua la configuración frente a referencias como los CIS Benchmarks.
- Envío de todo ello al SIEM corporativo.
- Alertas imprescindibles: uso de la cuenta raíz, cambios en IAM, desactivación del registro, recursos que pasan a ser públicos y picos anómalos de gasto.

## 9. Endpoints en cloud

Las máquinas virtuales siguen siendo servidores: se bastionan igual que en la UT3 y la UT4.

- Imágenes base ya bastionadas (*golden images*) y actualizadas con regularidad.
- Parcheo automatizado; mejor sustituir la instancia por una nueva que parchear a mano.
- Agente EDR o de protección de cargas de trabajo.
- Servicio de metadatos protegido (IMDSv2 en AWS) para que un fallo de la aplicación no permita robar las credenciales de la instancia.
- Sin claves SSH compartidas: acceso por gestor de sesiones y con registro.
- Discos e instantáneas cifrados y nunca compartidos públicamente.

## 10. Contenedores y Kubernetes

### 10.1. Imágenes

- Imágenes base mínimas y de origen fiable.
- Escaneo de vulnerabilidades en el registro y en la cadena de integración (Trivy, Gype).
- Sin secretos dentro de la imagen.
- Ejecución con usuario no root.

### 10.2. Ejecución

- Sistema de ficheros de solo lectura y sin capacidades innecesarias.
- Nunca contenedores privilegiados salvo causa muy justificada.
- Límites de CPU y memoria.

### 10.3. Kubernetes

- API del clúster no expuesta a Internet.
- RBAC con mínimo privilegio y cuentas de servicio específicas por aplicación.
- Políticas de red (NetworkPolicy) con denegación por defecto: es la microsegmentación del clúster.
- Estándares de seguridad de pods (Pod Security Standards) en nivel restringido.
- Secretos cifrados en etcd o en un gestor externo.
- Registro de auditoría del clúster activado.

## 11. Buenas prácticas globales

- Infraestructura como código (Terraform, Bicep), revisada y analizada antes de desplegar.
- Nada público por defecto.
- MFA y mínimo privilegio en todas las identidades.
- Cifrado en reposo y en tránsito siempre.

- Registro centralizado e inmutable.
- Etiquetado e inventario: no se puede proteger lo que no se sabe que existe.
- Presupuestos y alertas de coste: un gasto anómalo suele ser el primer síntoma de una cuenta comprometida.
- Revisión periódica frente a los CIS Benchmarks del proveedor.

### **Para ampliar**

- CIS Benchmarks de AWS, Azure, Google Cloud y Kubernetes.
- Guías CCN-STIC de la serie 880 (nube) para el cumplimiento del ENS.
- Cloud Security Alliance: Cloud Controls Matrix (CCM).
- OWASP Kubernetes Top 10.